

虚拟化和混合云环境下的 安全挑战与实践

GET INTO THE CLOUD
WITHOUT LEAVING THE GROUND

北京易思捷信息技术有限公司
张振宇

这是最好的时代，
也是最坏的时代.....

查尔斯·狄更斯

计算模式发展



云计算力量和障碍

云计算的力量

- 提高业务灵活性
- Business agility
- 降低成本
- Cost efficiencies
- 促进革新
- Enhanced innovation
- 改善IT服务
- Improved IT services

但是，安全还是路障

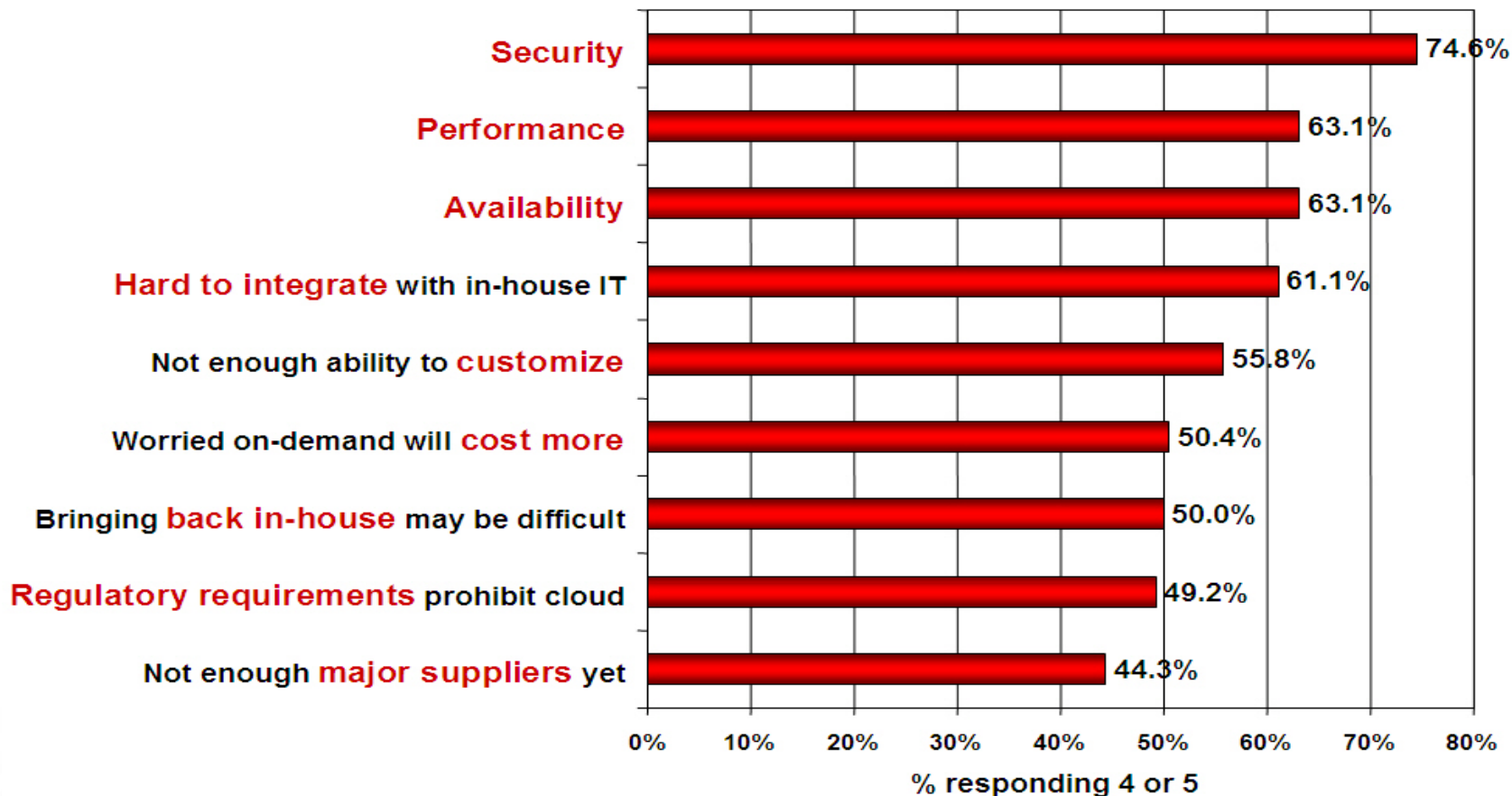
- 数据丢失
- Data loss
- 认证，授权，审计
- AuthN, AuthZ, Audit
- 信息治理
- Information governance
- 数据控制
- Data control



安全、安全，还是安全



Q: Rate the **challenges/issues** ascribed to the 'cloud'/on-demand model
(1=not significant, 5=very significant)



Source: IDC Enterprise Panel, August 2008 n=244

云安全需求



安全需求

虚拟化的好处

- Higher utilization
- Fast provisioning
- Flexibility
- Consolidation
- Disaster recovery

▪ Growing security breeches

▪ Cost of downtime/data Loss

▪ Risk of company image

▪ Consolidation

▪ Compliance, regulatory

Cloud Deployment Requires Balancing Security Tensions

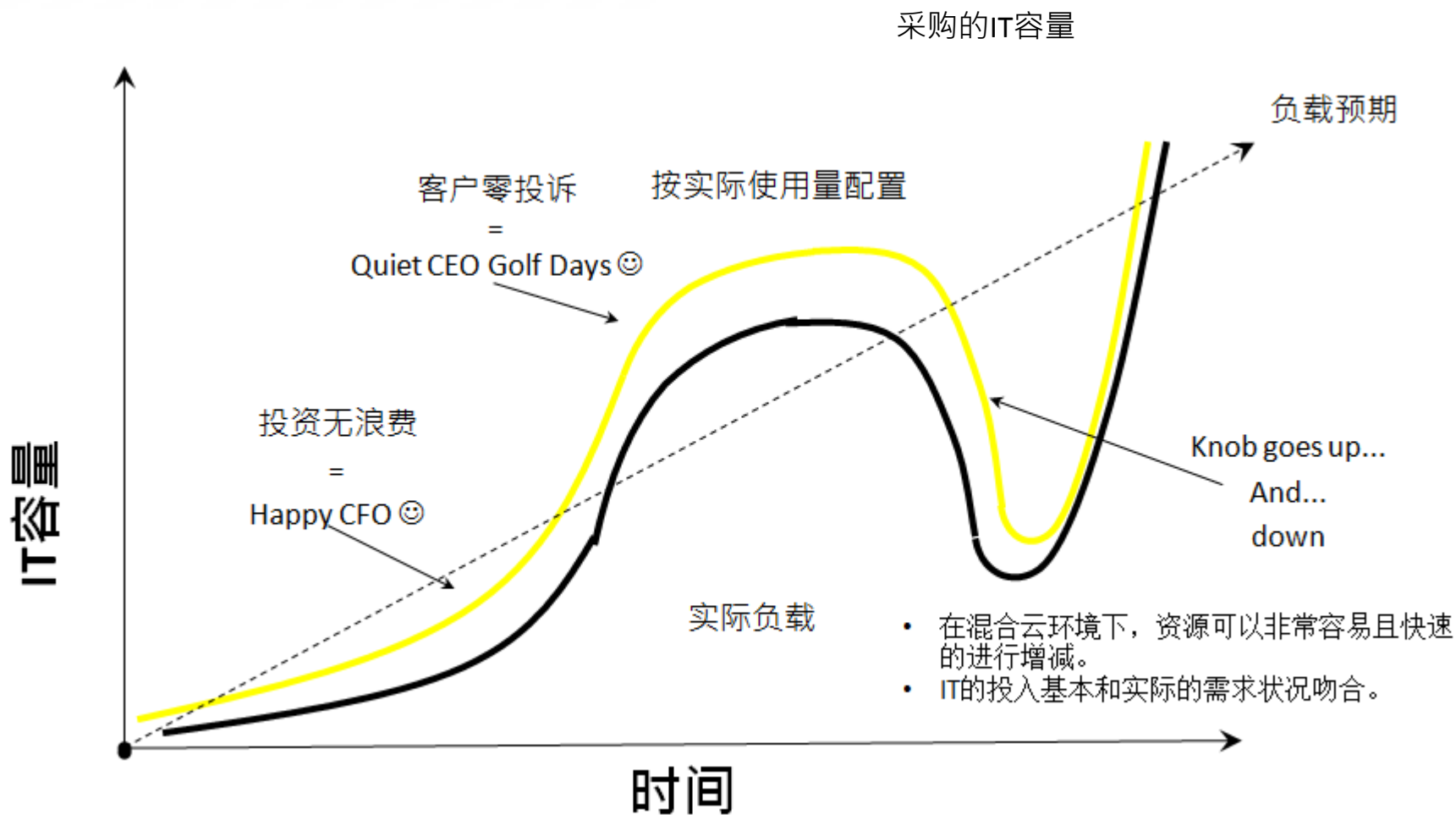
云安全概念



- 云安全服务（Cloud Security Service, Security **from** the cloud）
 - 如何利用云计算技术给用户提供安全服务
- 云计算安全（Cloud Computing Security, Security **for** the cloud）
 - 如何保护云计算环境本身的安全性
- 云安全智能（Cloud Security Intelligence, Security **in** the cloud）
 - 如何利用云的技术增强安全防护的技术能力



为什么是混合云?



云计算部署模型



	Infrastructure Managed By ¹	Infrastructure Owned By ²	Infrastructure Located ³	Accessible and Consumed By ⁴
Public	Third Party Provider	Third Party Provider	Off-Premise	Untrusted
Private/ Community	Or Organization Third Party Provider	Organization Third Party Provider	On-Premise Off-Premise	Trusted
Hybrid	<u>Both</u> Organization & Third Party Provider	<u>Both</u> Organization & Third Party Provider	Both On-Premise & Off-Premise	Trusted & Untrusted

¹ Management includes: governance, operations, security, compliance, etc...

² Infrastructure implies physical infrastructure such as facilities, compute, network & storage equipment

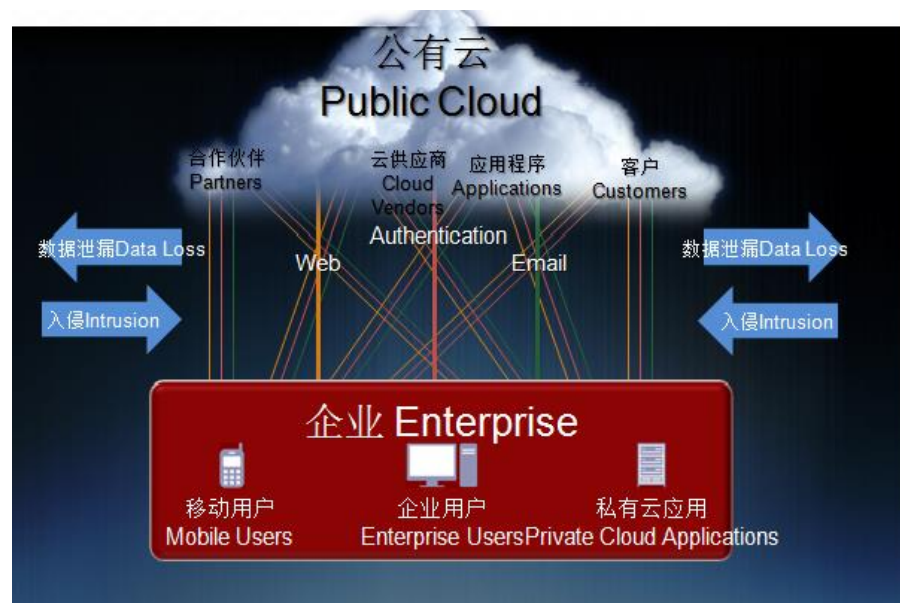
³ Infrastructure Location is both physical and relative to an Organization's management umbrella and speaks to ownership versus control

⁴ Trusted consumers of service are those who are considered part of an organization's legal/contractual/policy umbrella including employees, contractors, & business partners. Untrusted consumers are those that may be authorized to consume some/all services but are not logical extensions of the organization.

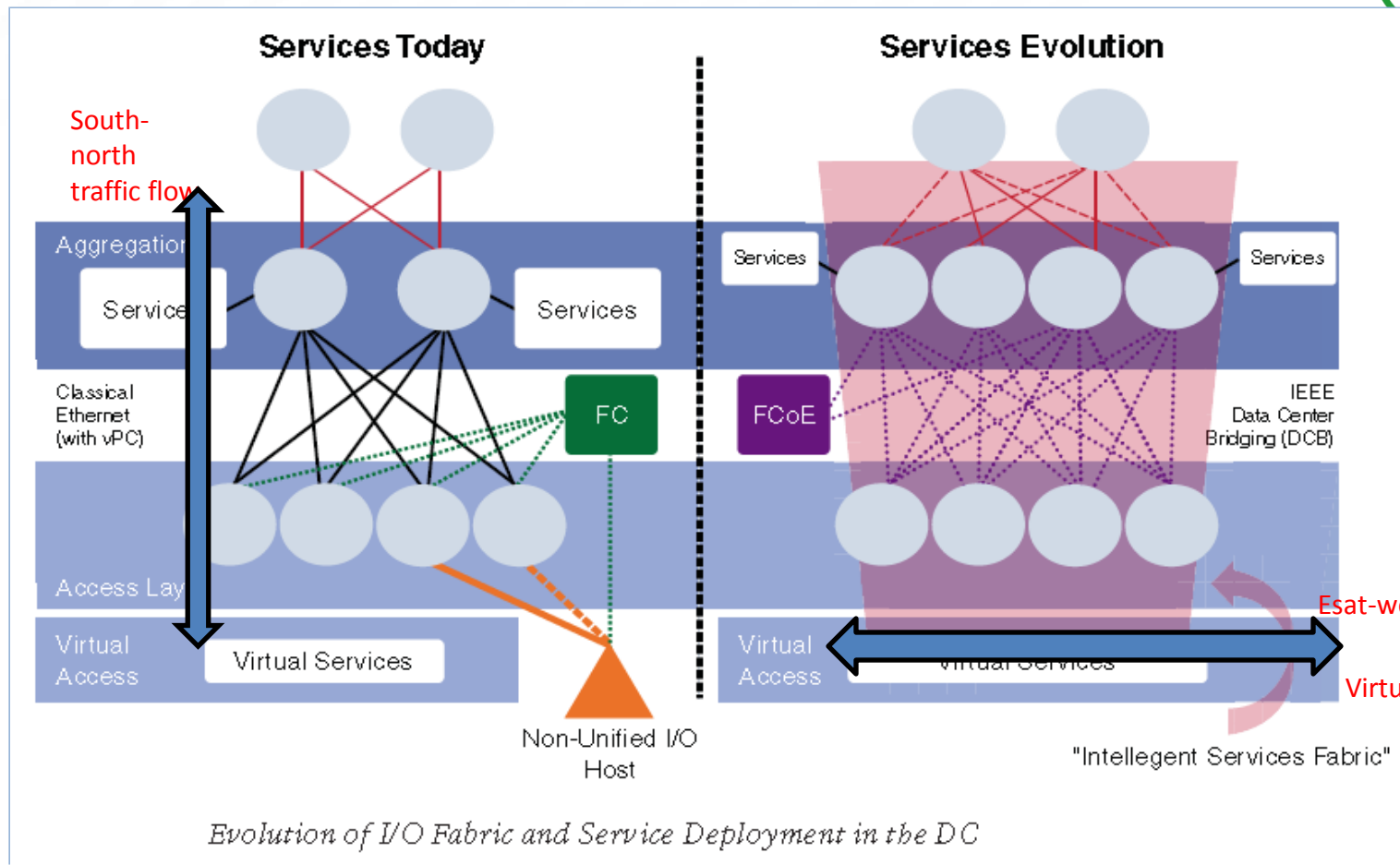
混合云面临的安全问题

混合云安全涉及许多因素：

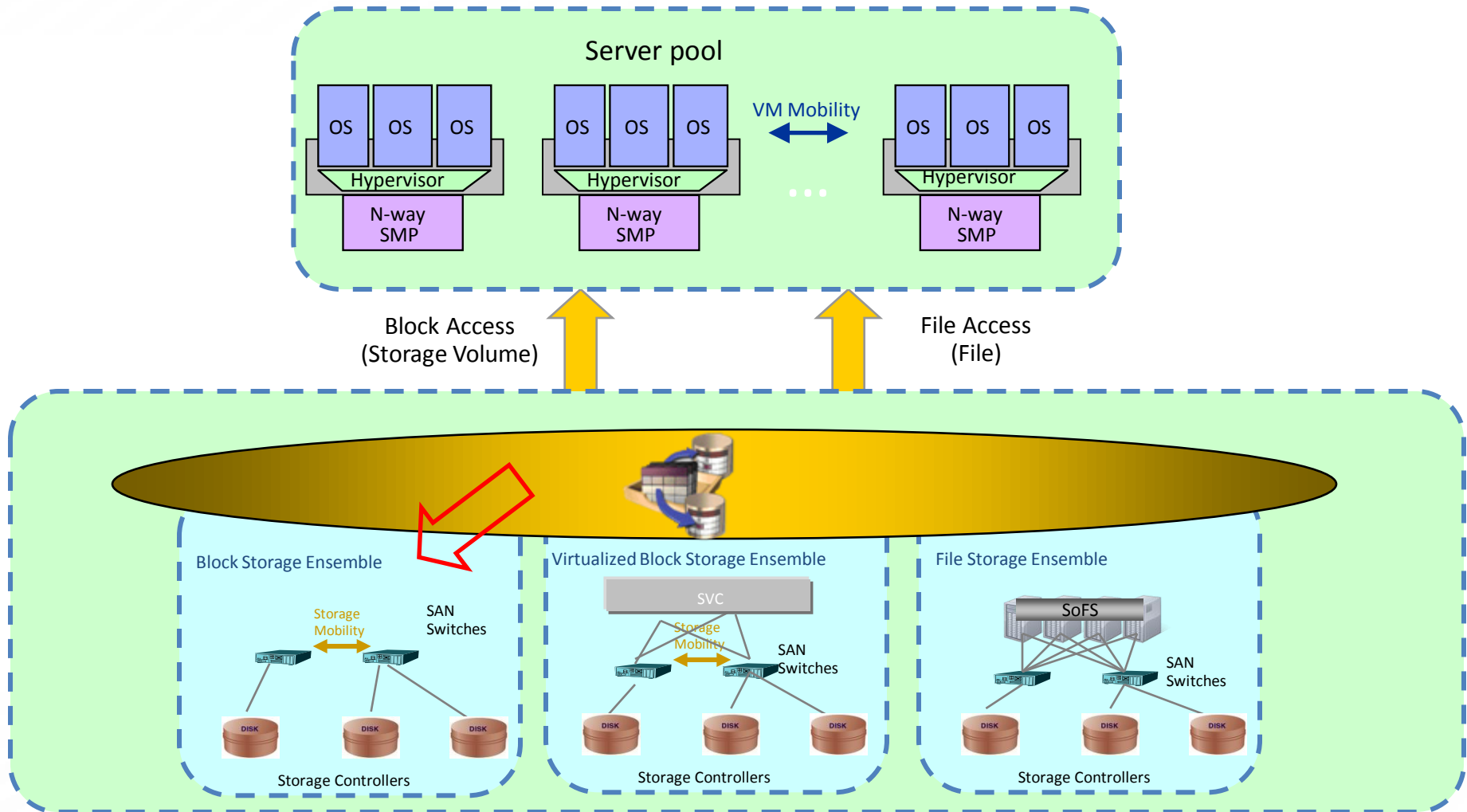
- 如何确保本地数据中心的资源安全
- 如何确保向公有云迁移的大量应用的安全
- 如何确保存储在多家云服务商上数据的安全
- 如何保护公有云和私有云的虚拟化基础
- 如何确保接入云基础设施的移动设备安全



挑战：下一代数据中心的网络结构演进



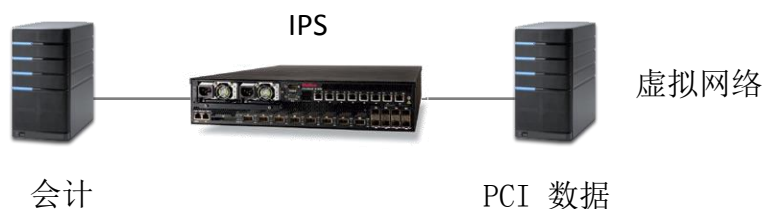
挑战：复杂的云计算存储架构下的数据安全 安全管理



挑战：虚拟化环境的网络防护



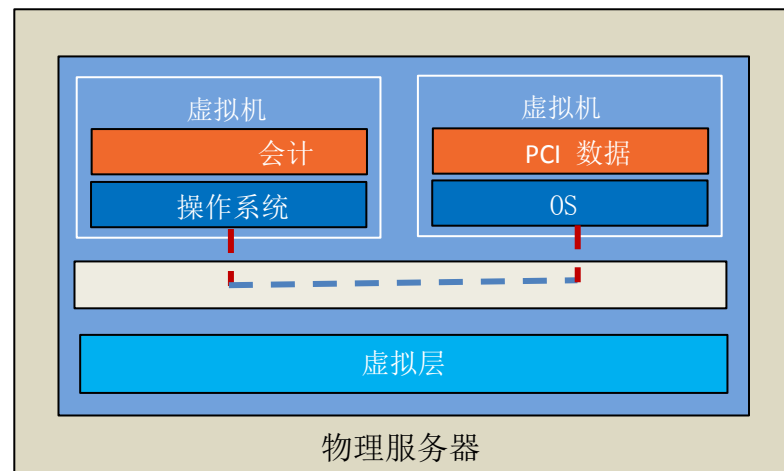
传统的安全设备需要
串联在网络中



PCI DSS 标准 11.4

“使用IDS和/或IPS来监控所有在持卡人数据环境中的流量。。。”

而虚拟化带来了问题



IPS

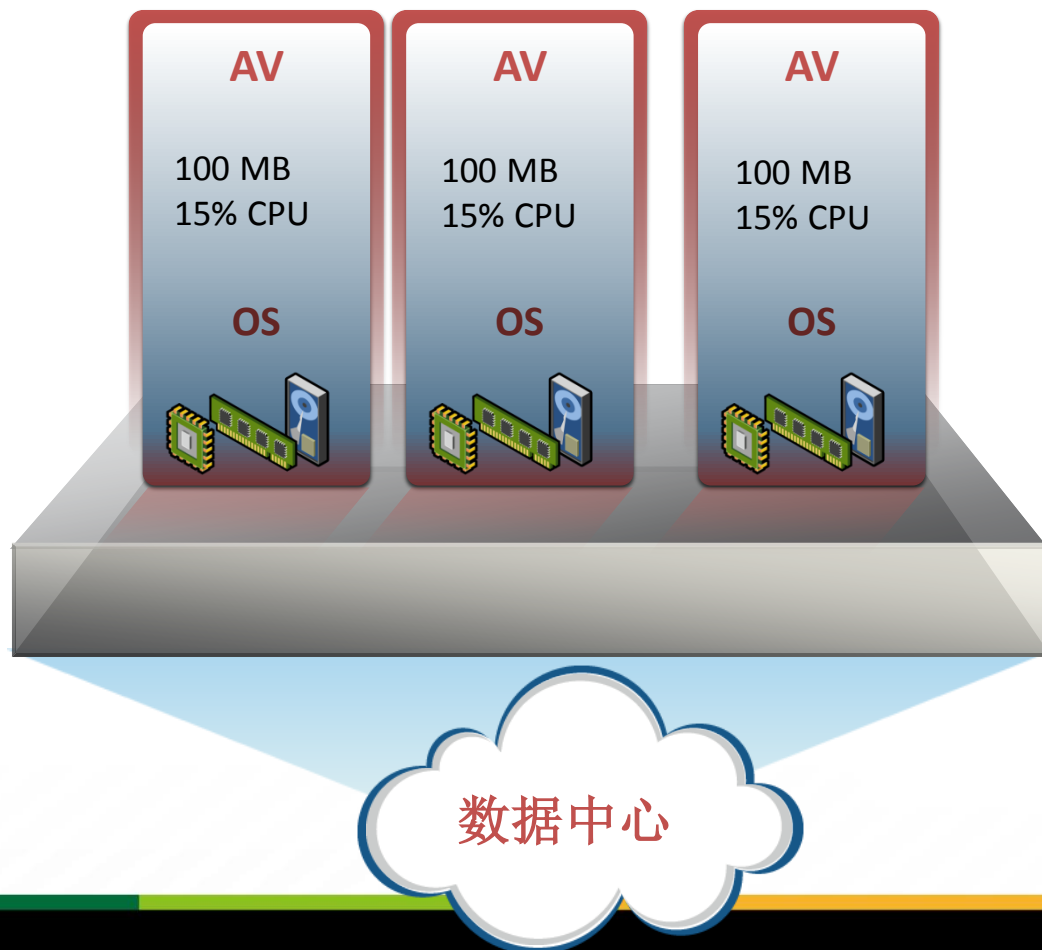
虚拟的流量没有被
路由到外部的网络

挑战：优化虚拟化安全系统



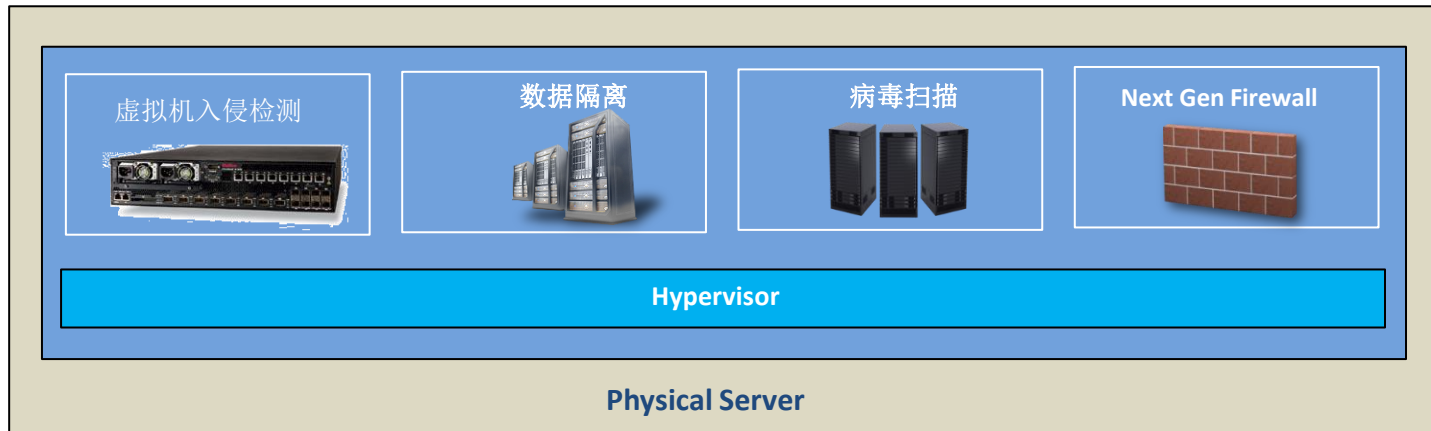
传统的没有针对虚拟环境进行优化的AV软件

- AV风暴
- 很高的磁盘I/O
- 很高的AV软件资源占用
- 对虚拟层加载状态的不可知
- 对于离线的虚拟机，无法升级DAT文件
- 无法集中管理异构虚拟化环境以及物理和虚拟环境



挑战：服务器虚拟化环境下的安全

同一物理机上虚拟机之间的安全隔离



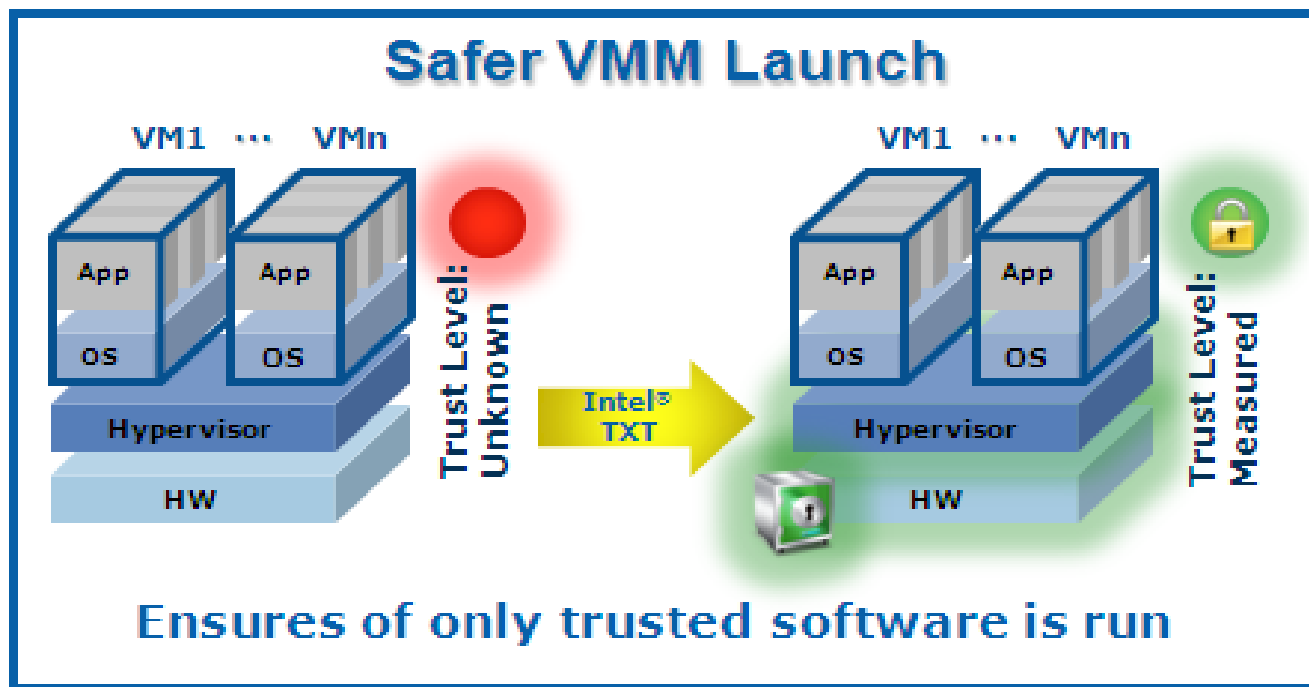
Traditional IPS

Network Security Platform

挑战：服务器虚拟化环境下的可信计算

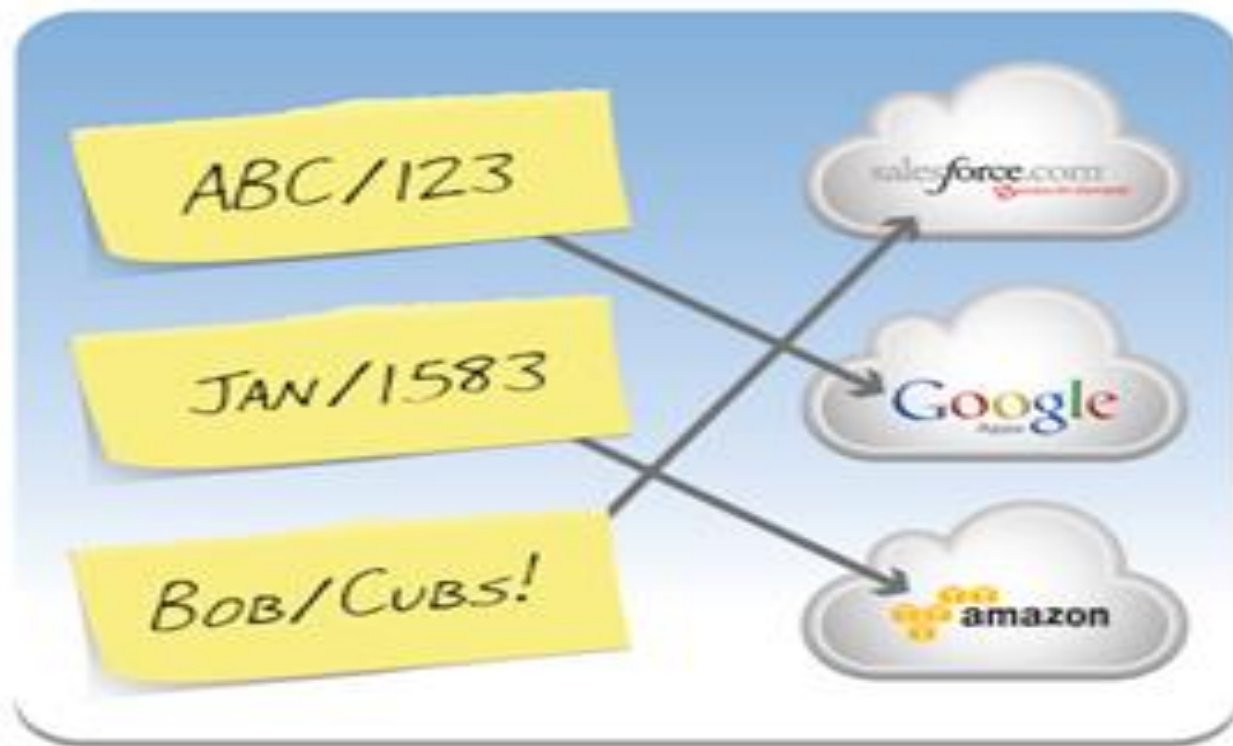


不采用TXT 和TPM，中国如何建立自己的可信计算标准



虚拟化和云计算环境下，迫切需要可信计算环境

挑战：云环境下的身份识别与访问控制



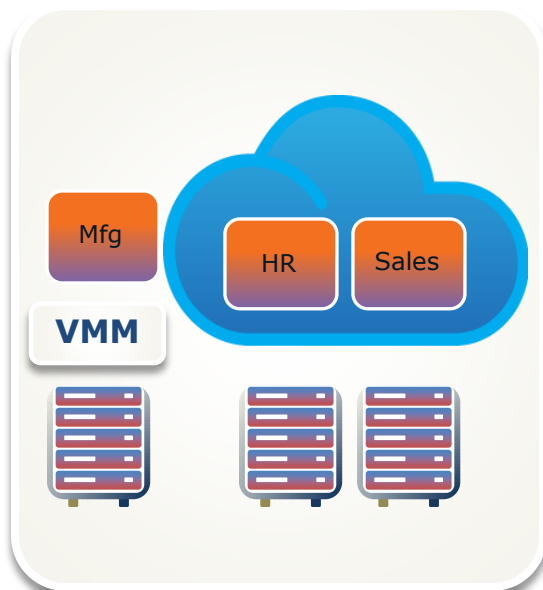
混合云环境要求统一的、高效的身份认证与访问控制机制

挑战：安全的数据传输



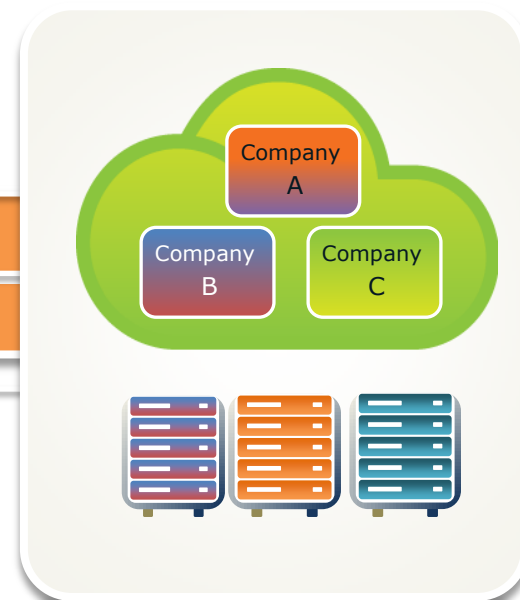
如何保证企业数据在私有云和公有云以及不同的云服务提供商之间的安全传输

**Virtualized and Private
Cloud Data Center**



**Data transport between
Private and public cloud**

**Public Cloud
Data Center**

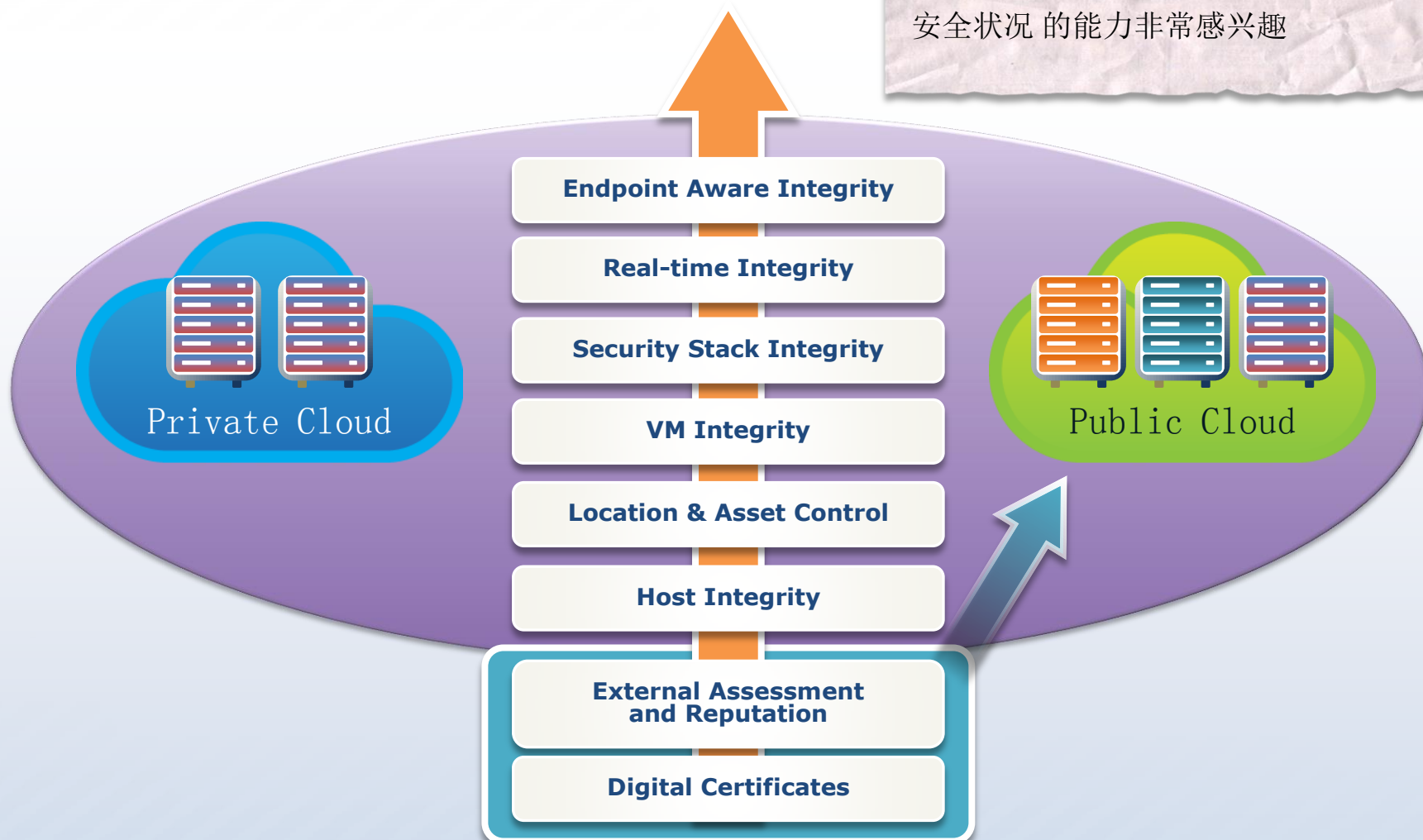


混合云环境下要求更全面地数据安全传输机制

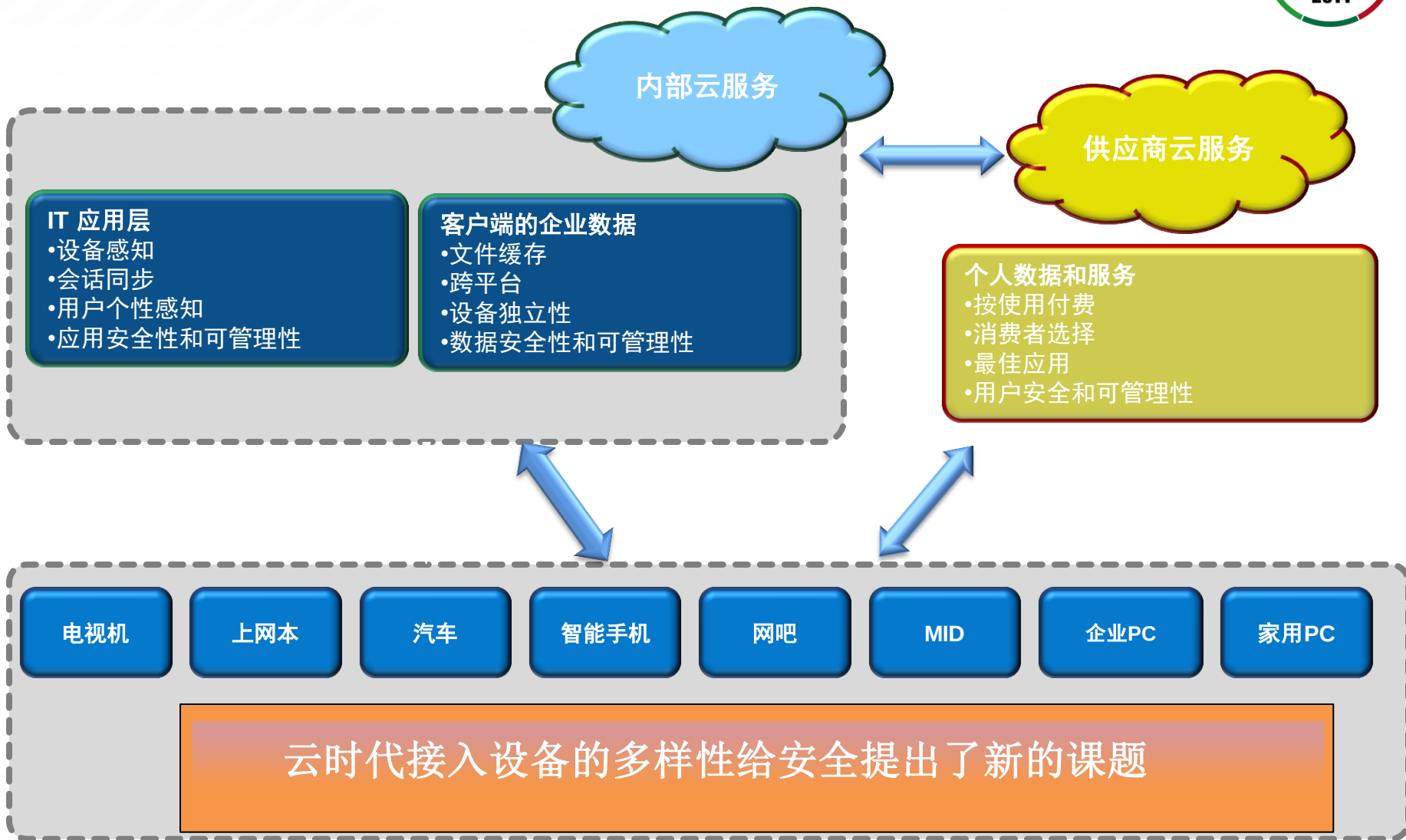
挑战：云安全控制点的演变



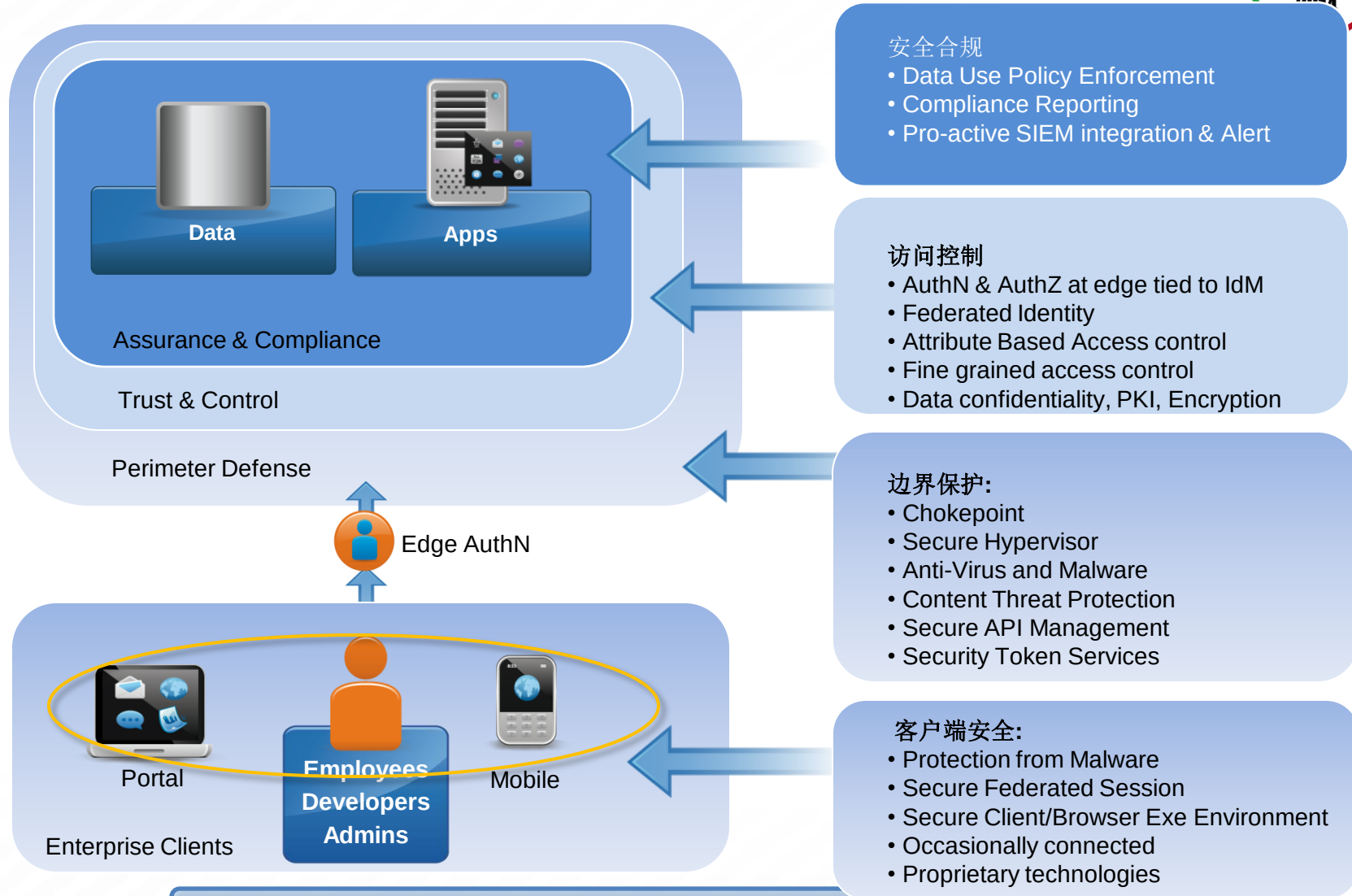
76% 的 IT 专家对于实时测量服务提供商安全状况 的能力非常感兴趣



挑战：接入设备的多样性



云安全的层次

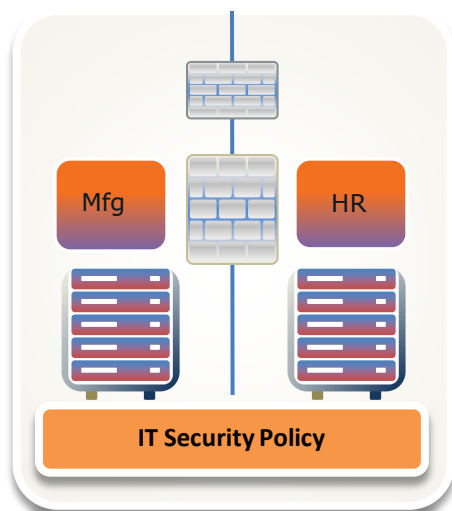


云计算的复杂性要求多层次的安全保护

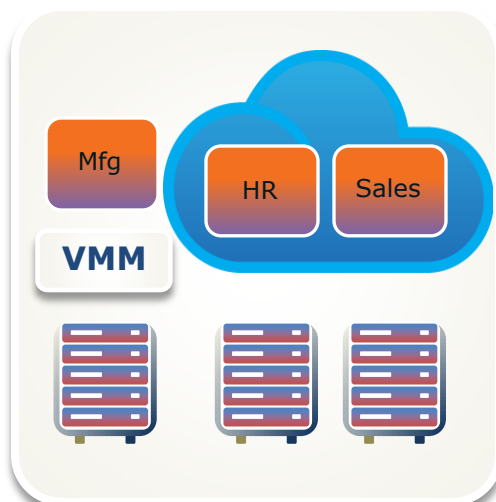
云计算驱动了新的安全需求



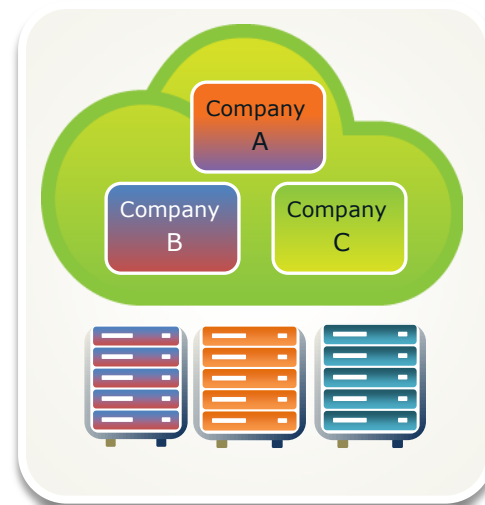
传统数据中心



虚拟化和私有云数据中心



公有云数据中心



挑战

- 物理控制、可视性降低
- 多租户
- 现有安全模式的低效
- 增加的安全控制点

- 新的安全模式
- 虚拟边界的防护
- 安全资源池
- 扩展的安全策略
- 统一的安全管理平台

虚拟云世界新的安全途径



虚拟化的、私有的云数据中心

公有云数据中心



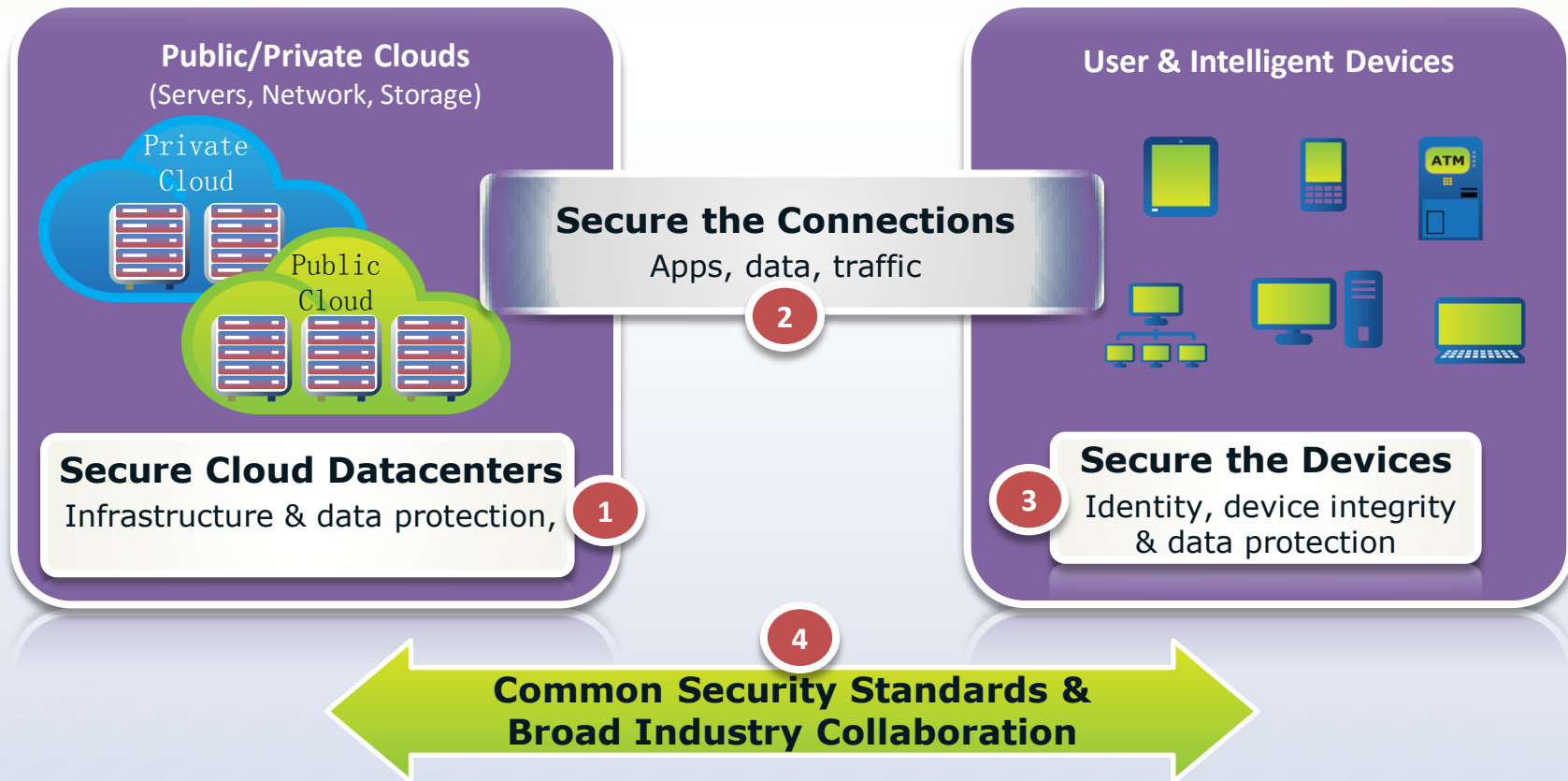
Enable secure, efficient, and simplified cloud data centers that allow IT flexibility & choice

整体云安全框架



Cloud Security Mission: Worry-Free Cloud Computing

In next 5 years, make cloud security equal to or better than traditional best in class enterprise security

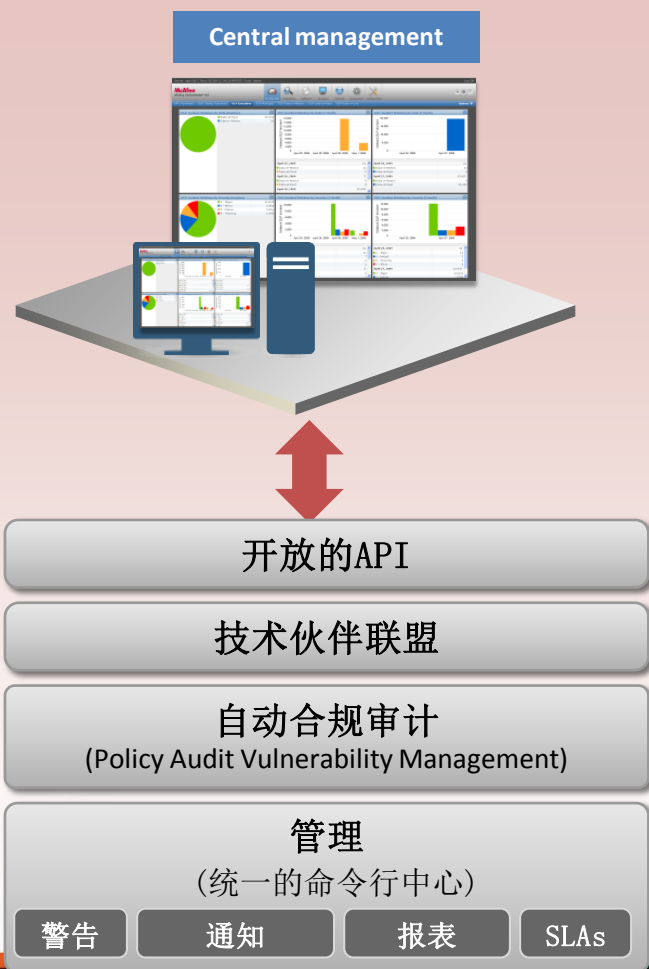


NGDC安全解决方案架构

-完善而开放的管理平台



- 跨越物理，虚拟和云的统一管理
 - 通过基于Web的界面，从任何地方进行访问
- 高度的扩展性
 - 有效的整合技术伙伴联盟
 - 通过API来适应不断变化的市场和业务的需求
- 端到端的可见和可控
 - 跨越应用、终端、服务器和网络等多个层次，深刻了解安全策略部署以及合规情况

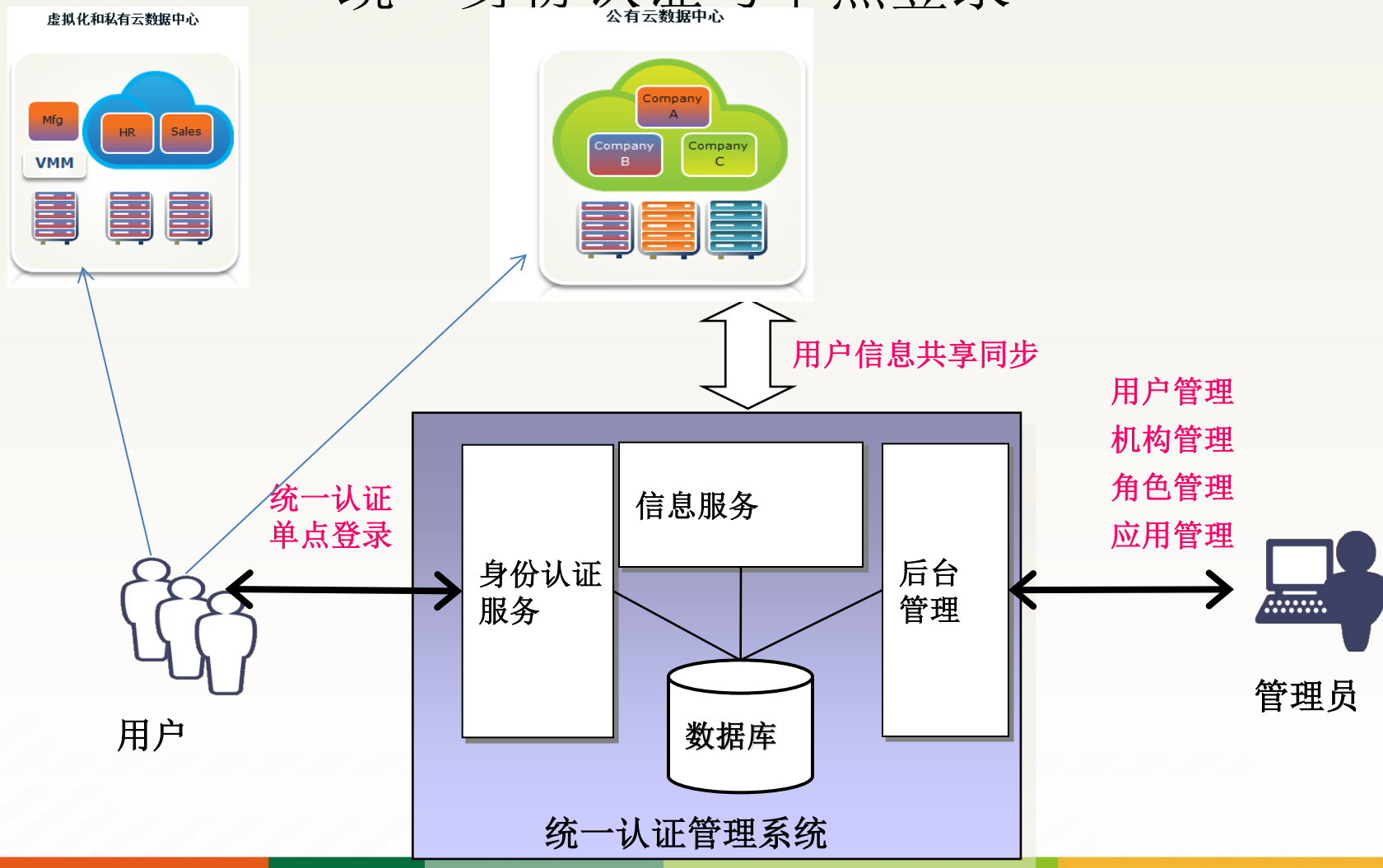


法规	框架	标准
SOX	ISO 27001	PCI DSS
HIPAA	COBIT	CIS
GLBA	NIST	NIST
FISMA		DISA STIGS
FDCC		

NGDC安全解决方案架构



-统一身份认证与单点登录



NGDC安全解决方案架构

-动态和层次化的网络保护



- 高度可扩展的网络安全防护架构
- 跨越物理和虚拟环境的保护
 - 对VM之间的流量进行实时查看和威胁检测
 - 不会对服务器造成另外的负载
- 支持更广泛的网络访问
 - 可以通过用户，组和应用程序进行策略设定，而不是仅仅通过静态属性（IP地址，MAC地址）来管理策略

NGDC安全解决方案架构

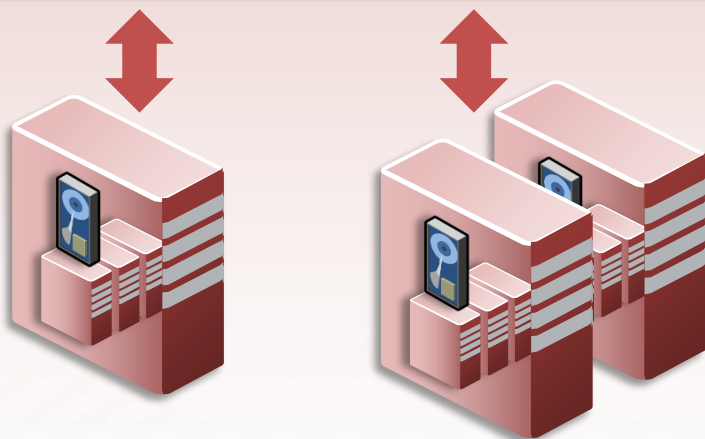


一可扩展的存储安全

针对存储的
恶意软件扫描模块

集中管理

直连存储及共享存储



- 针对存储设备的无缝保护
- 针对数据可用性最大化的可扩展架构
- 中央管理减少了管理负担

NGDC安全解决方案架构

-灵活的计算安全（物理和虚拟）



- 最大化虚拟机密度和可用性
 - 确保只有必须的应用在运行
 - 针对虚拟机设计的防病毒offload机制
 - 支持所有主流虚拟化厂商
 - 虚拟层感知能力
- 针对不同的层和应用进行灵活的保护
 - 黑名单、白名单和信誉技术
- 完全符合行业标准和最佳实践
 - 策略基准，策略变更管理，文件完整性监控
- 虚拟机移动和迁移
 - 支持在线的虚拟机迁移
 - 跨越物理，虚拟和云的安全策略一致性

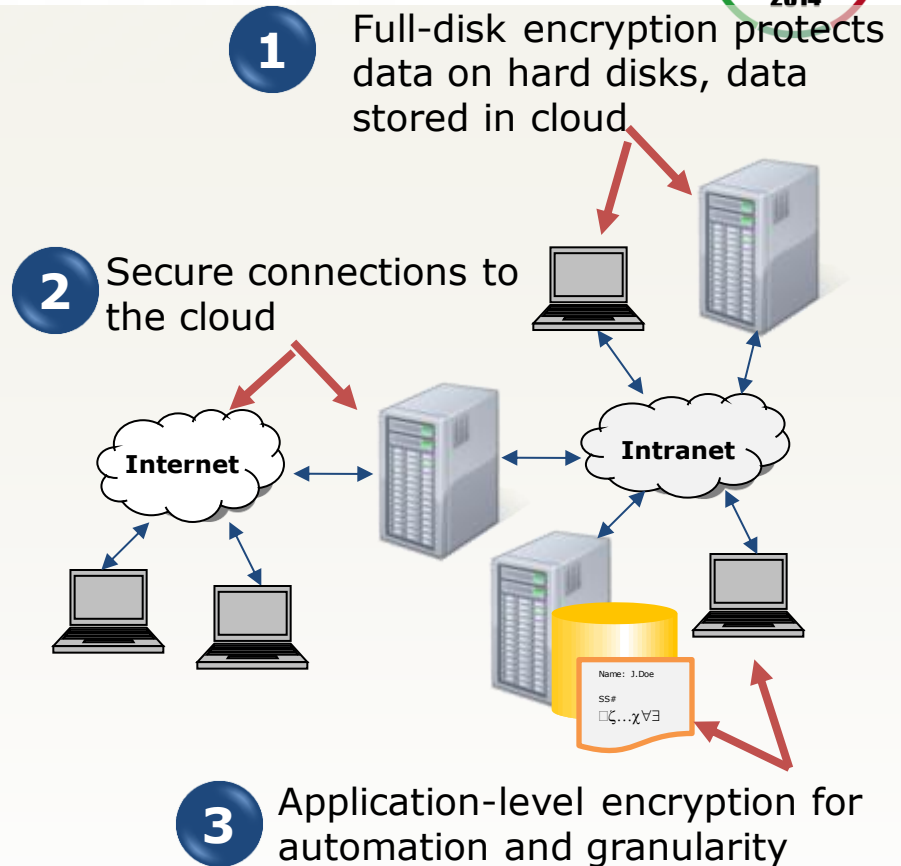
加密数据保护



1 Full disk encryption software protects data automatically during saving to disk

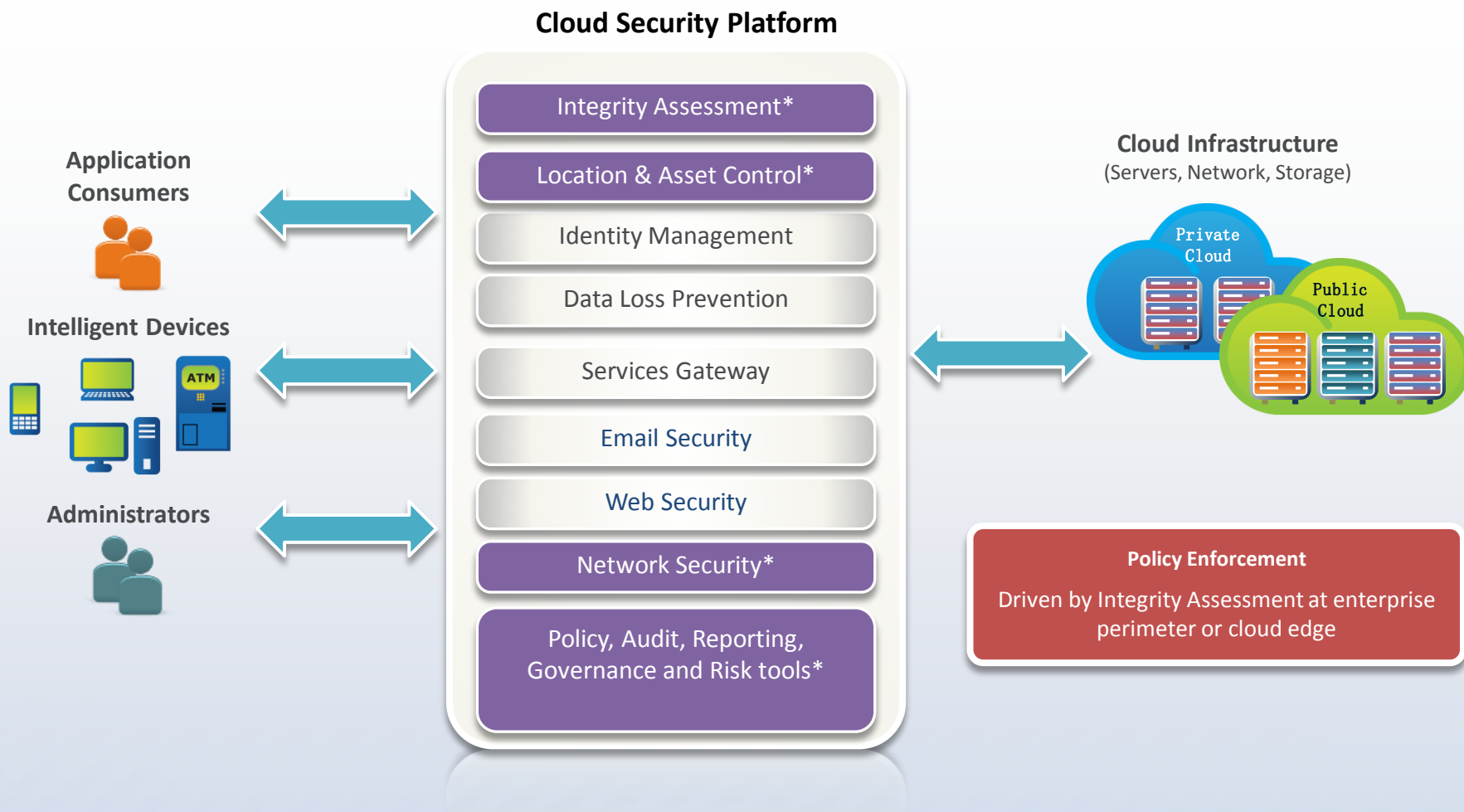
2 Secure transactions used pervasively in ecommerce, banking, etc.

3 Most enterprise and many cloud applications offer options to use encryption to secure information and protect confidentiality



在目前云安全诸多不确定的因素下，加密保护是目前最好的方法

端到端的数据传输安全保护



*denotes future capability

总结



- 混合云的复杂性决定了云安全的综合性和复杂性
- 虚拟化的特性打破了传统基于边界的安全防护，要求安全产品虚拟化并形成可基于策略随虚拟环境分布式部署的安全资源池
- 统一身份认证
- 数据加密
- 接入终端的安全性保证
- 三分技术，七分管理

A dramatic sunset sky with a bright sun partially obscured by dark, textured clouds. Sunbeams (crepuscular rays) radiate from the sun, illuminating the scene. The colors range from deep blues and greys in the upper parts of the sky to bright yellows and oranges near the horizon.

谢谢！